Azure Security Baseline & Governance (Least-Privilege, Secure Config, Guardrails) — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Azure Security Baseline & Governance (Government / GCC High) 4
- The situation . . . 4
- What this solution does . . . 4
- Why it is credible . . . 4
- How it is delivered . . . 4
- The outcome . . . 5

Solution Overview — Azure Security Baseline & Governance (Government / GCC High) 5
- What this solution delivers . . . 5
- Deployment model . . . 6
- Who this is for . . . 6
- Commercial vs Azure Government — what's different . . . 6
- What you will have at the end . . . 8

Requirements — Azure Security Baseline & Governance (Government / GCC High) 8
- R1. An Azure Government subscription in a GCC High / Azure Government tenant . . . 9
- R2. US Government licensing (Microsoft 365 G3/G5 Government + Azure plan) . . . 9
- R3. Administrative roles (least privilege) in the Gov tenant . . . 10
- R4. Management-group access enabled and root scope reachable . . . 10
- R5. Microsoft Defender for Cloud available and plan scope confirmed for Azure Government . . . 10
- R6. Log Analytics workspace capacity in a US Gov region . . . 11
- R7. Network egress to Azure Government (`*.us` / `usgovcloudapi.net`) endpoints . . . 11
- R8. PowerShell modules pinned for US Gov connectivity . . . 11

Implementation Guide — Azure Security Baseline & Governance (Government / GCC High) 12
- Stage A — Assess (read-only baseline) . . . 12
- Stage B — Configure (build objects, audit mode) . . . 13
- Stage C — Pilot (one subscription, guardrails live) . . . 15
- Stage D — Validate (evidence) . . . 15
- Stage E — Expand (remaining subscriptions) . . . 15
- Rollback (any stage) . . . 16

Testing & Validation — Azure Security Baseline & Governance (Government / GCC High) 16
- Test matrix . . . 16
- Detailed procedures . . . 17
- Regression / re-test cadence . . . 18

Troubleshooting — Azure Security Baseline & Governance (Government / GCC High) 18
- 1. "I signed in but see no subscriptions / resources" . . . 18
- 2. Sign-in redirect / "wrong version number" / TLS or AADSTS redirect errors . . . 19

3. A Defender for Cloud plan won't turn on / doesn't appear . . . 19
4. "Recommendation exemption" option is missing in Defender for Cloud . . . 19
5. Every deployment is suddenly blocked after assigning the policy initiative . . . 19
6. Legitimate work is blocked by a pilot `Deny` policy . . . 20
7. Management groups option is greyed out / root not visible . . . 20
8. "Just-in-time / eligible" role activation isn't available . . . 20
9. MFA "Trusted IPs" setting is missing . . . 20
10. Log Analytics workspace has no data / can't move Commercial data in . . . 21
11. Regulatory-compliance dashboard shows different / fewer standards than Commercial . . . 21
12. A built-in policy initiative or preview feature is missing . . . 21
13. A script says it refuses to run because the cloud is wrong . . . 21
Escalation checklist . . . 21
Best Practices — Azure Security Baseline & Governance (Government / GCC High) 22
1. Always confirm the cloud before you act . . . 22
2. Least privilege — standing scope, documented compensating controls . . . 22
3. Policy-first guardrails, audit before deny . . . 22
4. Enable only the Defender plans that exist in Gov . . . 23
5. Centralize audit logging in-cloud, keep it in-cloud . . . 23
6. Identity hardening the Gov way . . . 23
7. Change control, rollback, and evidence . . . 23
8. Keep tooling current and Gov-aware . . . 24
9. Naming discipline . . . 24
Deliverables Summary — Azure Security Baseline & Governance (Government / GCC High) 24
Documentation . . . 24
Scripts (`scripts/`) . . . 25
Named objects the solution creates . . . 25
How to use the package . . . 26
Definition of done . . . 26
Appendix A — PowerShell Scripts 27

Executive Summary — Azure Security Baseline & Governance (Government / GCC High)

The situation

Deploying a security baseline and governance guardrails on an **Azure Government / GCC High** tenant is not the same task as doing it in Commercial Azure. Azure Government is a **physically isolated US sovereign cloud** with its own portal (`portal.azure.us`), its own management endpoints (`management.usgovcloudapi.net`, `login.microsoftonline.us`, `graph.microsoft.us`), and a set of **feature-parity gaps** versus Commercial. Teams that reuse Commercial runbooks on a Gov tenant hit wrong URLs, features that appear missing, and silent failures — with real compliance and export-control consequences (FedRAMP High, ITAR/EAR data residency).

What this solution does

It delivers a **pilot-first, click-to-implement deployment** of the core Azure governance guardrails, authored specifically for the sovereign cloud:

- A named **management-group hierarchy** so policy and least-privilege RBAC apply by inheritance.
- A **least-privilege RBAC** model replacing broad standing `Owner`/`Contributor` grants.
- An assigned **Azure Policy security-baseline initiative** enforcing secure configuration (deny public storage, require encryption, **Allowed Locations pinned to US Gov regions**, audit diagnostics).
- **Microsoft Defender for Cloud** enabled with only the **Gov-available plans**, plus Secure Score and the regulatory-compliance dashboard.
- **Centralized audit logging** to a Gov-region Log Analytics workspace as FedRAMP-grade evidence.

Every object is named once and reused verbatim, and every step is executed against the correct `*.us` sovereign endpoints.

Why it is credible

The solution is built on **cited Microsoft Azure Government documentation**, not assumption. The Commercial-vs-Gov differences — endpoints, PowerShell environment switches (`-Environment AzureUSGovernment` / `USGov`), region names, and the specific Defender for Cloud plans that are **Not Available** in Gov (App Service, Cosmos DB, Foundry/AI, adaptive network hardening, legacy VA, AWS/GCP connectors, recommendation exemption rules) — are documented with source links in `gcc-high-parity-notes.md`. Where Microsoft's docs do not confirm a Gov specific, the solution states the Commercial path and flags it **"verify for Azure Government"** rather than inventing a fact.

How it is delivered

- **Documentation:** overview (with an explicit Commercial-vs-Gov section), requirements, ordered implementation, testing, troubleshooting, best practices, and a parity reference.
- **Five PowerShell scripts** targeting US Gov endpoints: Discovery, Validation, and Report (read-only); Remediation and Set-ScopeTargeting (default to `-WhatIf`).

• **Method:** Assess → Configure → Pilot → Validate → Expand, with a pass/fail gate at each stage and a rehearsed rollback.

The outcome

A GCC High tenant with governance guardrails **correctly deployed on the right cloud** — right portals, right endpoints, parity gaps handled — proven on a pilot subscription before scaling, with audit evidence in hand. Self-guided and repeatable, at a fraction of bespoke consulting cost.

Solution Overview — Azure Security Baseline & Governance (Government / GCC High)

This is the **Government (GCC High / Azure Government) edition** of the Azure Security Baseline & Governance solution. It deploys a least-privilege, secure-configuration, guardrail-based governance baseline on a **US sovereign cloud** tenant — using the correct `*.us` sovereign portals and US Gov service endpoints, with every Commercial-vs-Azure-Government difference called out at the point where it matters.

> *This edition is **not** the Commercial portal reached through a different sign-in. Azure Government is a physically isolated cloud with its own portal (`portal.azure.us`), its own Resource Manager endpoint (`management.usgovcloudapi.net`), its own identity authority (`login.microsoftonline.us`), and a set of feature-parity gaps versus Commercial. Following Commercial steps on a GCC High tenant leads to wrong URLs, features that appear missing, and silent failures. Source: [Compare Azure Government and global Azure](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure).*

What this solution delivers

A repeatable, pilot-first deployment of the core Azure governance guardrails on an Azure Government subscription:

1. **Management-group structure** — a governance hierarchy (`Governance Root MG` → `Platform MG`, `Landing Zones MG`) so policy and RBAC apply by inheritance rather than per-subscription.
2. **Least-privilege RBAC** — custom and built-in role assignments scoped at the management-group / subscription level, replacing broad standing `Owner`/`Contributor` grants.
3. **Azure Policy guardrails** — a assigned policy initiative (`Security Baseline Initiative – Governance Root – Pilot`) enforcing secure configuration (deny public storage, require encryption, allowed locations = US Gov regions, audit missing diagnostic settings).
4. **Microsoft Defender for Cloud** — enabled on the subscription with the Foundational CSPM (free) tier and the paid Defender plans **that are available in Azure Government**, plus Secure Score tracking.
5. **Diagnostic + audit logging** — a Log Analytics workspace (`Governance Logs Workspace – Platform – Pilot`) receiving activity and resource logs for audit evidence.

Every object is named `<Purpose> – <Scope> – <Stage>` (e.g. `Security Baseline Initiative – Governance Root – Pilot`) and reused verbatim across the guide, scripts, and validation.

Deployment model

The solution follows the standard **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model with an explicit pass/fail gate at each stage:

Stage	Goal	Pass/fail gate
Assess	Inventory current subscriptions, roles, policy state, Defender coverage in the Gov tenant.	Discovery script returns a clean baseline report; no blocking prerequisite gaps.
Configure	Build the MG structure, custom roles, policy initiative, Defender plans, workspace — **in audit/**`-WhatIf` **mode first**.	All objects created with the exact names; policy in `Audit`/`AuditIfNotExists` effect.
Pilot	Apply guardrails to **one pilot subscription** only.	Validation script passes on the pilot scope; no unexpected `Deny` blocks legitimate work.
Validate	Confirm compliance, Secure Score movement, log flow, no broken access.	Validation + Report scripts show target compliance; sign-off recorded.
Expand	Move guardrails to remaining subscriptions via `Set-ScopeTargeting`.	Expanded scope passes validation; rollback rehearsed.

Who this is for

A competent-but-novice Azure administrator operating a **GCC High / Azure Government** tenant who needs to stand up governance guardrails correctly the first time, without assuming Commercial behavior. No prior Azure Government experience is assumed; every portal path uses `portal.azure.us` and every script connects with `-Environment AzureUSGovernment` (Az) / `-Environment USGov` (Microsoft Graph).

Commercial vs Azure Government — what's different

This is the single most important section to read before starting. If you have deployed this baseline in Commercial Azure, **do not** reuse those URLs, endpoints, or feature assumptions. The table below is the summary; the companion file `gcc-high-parity-notes.md` carries the full list with a Microsoft doc URL or a "verify" flag for each item.

Portals and endpoints (always different)

Purpose	Commercial (do NOT use here)	Azure Government (use this)
Azure portal	`portal.azure.com`	`portal.azure.us`
Azure Resource Manager	`management.azure.com`	`management.usgovcloudapi.net`

Purpose	Commercial (do NOT use here)	Azure Government (use this)
Entra ID / sign-in authority	`login.microsoftonline.com`	`login.microsoftonline.us`
Microsoft Graph	`graph.microsoft.com`	`graph.microsoft.us` (DoD: `dod-graph.microsoft.us`)
Microsoft 365 / Entra admin	`admin.microsoft.com` / `entra.microsoft.com`	`portal.office365.us` / Entra via `portal.azure.us`
Key Vault	`vault.azure.net`	`vault.usgovcloudapi.net`
Storage (blob)	`blob.core.windows.net`	`blob.core.usgovcloudapi.net`
Log Analytics workspace portal	`mms.microsoft.com`	`oms.microsoft.us`

Source: [Compare Azure Government and global Azure — endpoint mapping](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#guidance-for-developers).

PowerShell / CLI connection (always different)

- **Az PowerShell:** `Connect-AzAccount -Environment AzureUSGovernment`. Confirm endpoints with `Get-AzEnvironment -Name AzureUSGovernment`. Source: [Connect to Azure Government with PowerShell](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).
- **Microsoft Graph PowerShell:** `Connect-MgGraph -Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD). Source: [Microsoft Graph national cloud deployments](https://learn.microsoft.com/en-us/graph/deployments).
- **Azure CLI:** `az cloud set --name AzureUSGovernment` before `az login`. Source: [Connect to Azure Government with Azure CLI](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-cli).

Region names (always different)

Azure Government resources deploy only to Gov regions: `usgovvirginia`, `usgovtexas`, `usgovarizona` (and DoD: `usdodeast`, `usdodcentral`). The **Allowed Locations** policy in this baseline is set to these values — never `eastus`/`westus`. Source: [Connect to Azure Government with PowerShell — regions](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).

Feature parity gaps that affect THIS baseline (doc-confirmed)

Per Microsoft's [Cloud feature availability for commercial and US Government customers](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability) (updated 2026), the following are **Not Available** in Azure Government and change how you build this baseline:

- **Microsoft Defender for Cloud — recommendation exemption rules** → Not Available. Plan governance around this: you cannot exempt individual recommendations; use policy exemptions or scope instead.
- **Defender for App Service, Defender for Azure Cosmos DB, Defender for Foundry/AI tools** → Not Available. Do **not** attempt to enable these plans; the baseline enables only the Gov-available plans (Servers, Storage, Key Vault, Resource Manager, Containers, SQL, DNS, open-source DBs).

• **Adaptive network hardening** and **Integrated vulnerability assessment for machines** (the legacy built-in VA) → Not Available. Use Defender for Servers' Microsoft Defender Vulnerability Management integration instead (verify plan coverage in your tenant).

• **Connect AWS / GCP account** (multicloud) → Not Available. This baseline is Azure-Gov-only; do not scope multicloud connectors.

• **Azure Lighthouse PIM (eligible/JIT) authorization** → Not enabled in Azure Government. If your RBAC design assumed PIM-eligible delegated access via Lighthouse, that path is unavailable — use standing scoped RBAC and document the compensating control. Source: [Compare Azure Government — Azure Lighthouse](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-lighthouse).

• **Microsoft Entra multifactor authentication — Trusted IPs** → Not supported in Azure Government. Use **Conditional Access named locations** instead. Source: [Compare Azure Government — Microsoft Entra ID](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#microsoft-entra-id-p1-and-p2).

• **Azure AD B2C** → Not available in Azure Government (not used by this baseline, noted for completeness).

Everything else in this baseline — management groups, Azure Policy, custom RBAC roles, Log Analytics, Secure Score — is available in Azure Government and behaves as in Commercial, only via the `*.us` portals and endpoints. Where a specific sub-feature is not confirmed in the Microsoft docs above, this guide states the Commercial path and flags it **"verify for Azure Government"** rather than asserting parity.

What you will have at the end

• A named management-group governance hierarchy on your Gov tenant.

• A least-privilege RBAC model with the broad standing grants removed or reduced.

• An assigned Azure Policy security-baseline initiative enforcing secure configuration, proven on a pilot subscription.

• Microsoft Defender for Cloud enabled with the Gov-available plans and a tracked Secure Score.

• Centralized audit logging in a named Log Analytics workspace.

• Evidence: discovery, validation, and report outputs proving the baseline is in place — all read from US Gov endpoints.

Requirements — Azure Security Baseline & Governance (Government / GCC High)

These are the solution-specific prerequisites for deploying the security baseline & governance guardrails on an **Azure Government / GCC High** tenant. They layer on top of the platform baseline in `global-requirements-azure-solutions.md` (tenant, admin roles, licensing, connectivity, change control, rollback).

Each requirement is structured **Description / Why / Verify / Implement-if-missing**. Every "Verify" step uses the **Azure Government** sovereign portal (`portal.azure.us`) or a US Gov PowerShell endpoint — never the Commercial equivalents.

> *Reminder: sign in at* `https://portal.azure.us` *(Azure) and* `https://portal.office365.us` *(Microsoft 365 / Entra admin). If you land on* `portal.azure.com`*, you are in the wrong cloud and none of the steps below apply.*

R1. An Azure Government subscription in a GCC High / Azure Government tenant

• **Description:** An active subscription hosted in Azure Government (US Gov regions), in a tenant whose identity is homed in `login.microsoftonline.us`.

• **Why:** All governance objects (management groups, policy, RBAC, Defender for Cloud) are created inside this subscription/tenant. A Commercial subscription cannot be governed by Gov-cloud objects, and the two clouds do not share portals or data. Source: [Compare Azure Government — Azure Monitor FAQ](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-monitor).

• **Verify:** Sign in to `https://portal.azure.us` → **Subscriptions**. Confirm at least one subscription is **Active** and its region shows a US Gov region (`USGov Virginia`, `USGov Texas`, `USGov Arizona`, or DoD). In PowerShell: `Connect-AzAccount -Environment AzureUSGovernment` then `Get-AzSubscription`.

• **Implement-if-missing:** Provision an Azure Government subscription through an authorized government channel (AOS-G reseller or an existing Gov Enterprise Agreement). Azure Government access is limited to eligible US government entities and their partners.

R2. US Government licensing (Microsoft 365 G3/G5 Government + Azure plan)

• **Description:** Government SKUs for any identity/security features used — e.g. **Microsoft 365 G3/G5 Government** (GCC High) for Entra ID P1/P2 and Defender workloads, plus the Azure plan for Defender for Cloud paid plans.

• **Why:** Conditional Access, PIM-adjacent controls, and Defender features are gated by Government license SKUs; Commercial SKUs do not apply to a GCC High tenant. Microsoft Entra ID P1/P2 feature availability in Gov has known limitations. Source: [Compare Azure Government — Microsoft Entra ID P1 and P2](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#microsoft-entra-id-p1-and-p2).

• **Verify:** In `https://portal.office365.us` → **Billing** → **Licenses**, confirm the Government SKUs are present and assigned. For Defender for Cloud, no separate license is needed — the paid plans bill per resource once enabled on the subscription.

• **Implement-if-missing:** Procure the correct **Government** SKUs (not Commercial) through your Gov licensing channel. Confirm subscription quota for Log Analytics ingestion and any VMs to be protected.

R3. Administrative roles (least privilege) in the Gov tenant

• **Description:** The roles needed to build the baseline: **Global Administrator** (or Privileged Role Administrator) for tenant-level Entra changes, **Owner** at the management-group root (or the target subscription) to create MGs, custom roles, and policy assignments, and **Security Admin** for Defender for Cloud.

• **Why:** Creating management groups and assigning policy at the root requires elevated scope; Defender plan changes require Security Admin. Least-privilege scoping limits blast radius and satisfies FedRAMP High audit expectations.

• **Verify:** In `portal.azure.us` → **Microsoft Entra ID** → **Roles and administrators**, confirm your operating account holds the directory roles. In **Management groups** → **(root)** → **Access control (IAM)**, confirm the `Owner`/`User Access Administrator` assignment. Note: in Azure Government, **Azure Lighthouse PIM (eligible/JIT) is not enabled**, so "eligible" activation is unavailable — roles here are standing assignments. Source: [Compare Azure Government — Azure Lighthouse](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-lighthouse).

• **Implement-if-missing:** Assign the minimum roles needed at the highest scope you actually need (prefer management-group scope over per-subscription). Document standing assignments as a compensating control where PIM-eligible access would normally be used.

R4. Management-group access enabled and root scope reachable

• **Description:** The ability to manage the tenant's **management group** hierarchy (the `Tenant Root Group` and children).

• **Why:** This baseline applies policy and RBAC by inheritance from management groups. Management groups are available in Azure Government. Source: [Compare Azure Government — Management and governance](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#management-and-governance).

• **Verify:** In `portal.azure.us` → search **Management groups**. If prompted, click **Start using management groups**. Confirm you can see the `Tenant Root Group`. In PowerShell: `Get-AzManagementGroup`.

• **Implement-if-missing:** A Global Administrator must **elevate access** (Entra ID → Properties → *Access management for Azure resources* → Yes) once to gain `User Access Administrator` at root, create the hierarchy, then remove the elevation. This behaves as in Commercial but is performed in `portal.azure.us`.

R5. Microsoft Defender for Cloud available and plan scope confirmed for Azure Government

• **Description:** Defender for Cloud reachable on the subscription, with awareness of **which paid plans are available in Azure Government**.

• **Why:** Several Defender for Cloud plans and features are **Not Available** in Azure Government. Enabling an unavailable plan is impossible and wastes time; the baseline must enable only Gov-available plans. Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

• **Verify:** In `portal.azure.us` → **Microsoft Defender for Cloud** → **Environment settings** → **(subscription)** → **Defender plans**. Confirm the available plans render. **Available in Azure Government:** Defender for Servers, Storage, Key Vault, Resource Manager, Containers, DNS, Azure SQL, SQL on machines, open-source relational DBs. **Not Available in Azure Government (do not attempt):** Defender for App Service, Defender for Azure Cosmos DB, Defender for Foundry/AI tools; feature-level: Adaptive network hardening, Integrated VA for machines (legacy), AWS/GCP connectors, recommendation exemption rules.

• **Implement-if-missing:** If Defender for Cloud does not render, confirm the subscription is registered for the `Microsoft.Security` resource provider (**Subscriptions** → **Resource providers** → **Microsoft.Security** → **Register**). Then enable only the Gov-available plans.

R6. Log Analytics workspace capacity in a US Gov region

• **Description:** A Log Analytics workspace (this baseline creates `Governance Logs Workspace – Platform – Pilot`) in a US Gov region to receive activity and diagnostic logs.

• **Why:** Centralized audit logging is the evidence layer for governance and is required by FedRAMP High controls. Azure Monitor / Log Analytics is available in Azure Government but uses the `oms.microsoft.us` / `*.opinsights.azure.us` endpoints, and **workspaces/data cannot be migrated between Commercial and Gov**. Source: [Compare Azure Government — Azure Monitor](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-monitor).

• **Verify:** In `portal.azure.us` → **Log Analytics workspaces**, confirm you can create a workspace in a US Gov region. Confirm ingestion quota under **Subscriptions** → **Usage + quotas**.

• **Implement-if-missing:** Create the workspace in the target Gov region (the Implementation Guide does this by the exact name). Ensure firewall/proxy allows `*.oms.microsoft.us`, `*.ods.opinsights.azure.us`, and `*.ods.opinsights.azure.us`.

R7. Network egress to Azure Government (`*.us` / `usgovcloudapi.net`) endpoints

• **Description:** Firewall/proxy allowances for the **Azure Government** endpoint set, not the Commercial set.

• **Why:** Every portal action and script call targets `*.us` / `*.usgovcloudapi.net` hosts. If only Commercial endpoints are allowed, sign-in and management calls fail silently or with TLS/redirect errors. Source: [Compare Azure Government — endpoint mapping](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#guidance-for-developers).

• **Verify:** From an admin workstation, confirm reachability to `login.microsoftonline.us`, `management.usgovcloudapi.net`, `graph.microsoft.us`, `portal.azure.us`, and `*.opinsights.azure.us` (HTTPS/443).

• **Implement-if-missing:** Add the Azure Government endpoint set to the allow-list. Use `Get-AzEnvironment -Name AzureUSGovernment` to enumerate the exact endpoints your tooling will call.

R8. PowerShell modules pinned for US Gov connectivity

• **Description:** Current **Az** PowerShell module and **Microsoft.Graph** PowerShell module installed, capable of the `AzureUSGovernment` / `USGov` environment switches.

• **Why:** The five solution scripts connect exclusively to US Gov endpoints via `-Environment AzureUSGovernment` (Az) and `-Environment USGov` (Graph). Older or missing modules will not resolve the Gov environment. Source: [Microsoft Graph national cloud deployments](https://learn.microsoft.com/en-us/graph/deployments).

• **Verify:** `Get-Module Az.Accounts,Az.Resources,Az.Security -ListAvailable` and `Get-Module Microsoft.Graph.Authentication -ListAvailable`. Confirm `Get-AzEnvironment -Name AzureUSGovernment` returns endpoints and `(Get-MgEnvironment).Name` includes `USGov`.

• **Implement-if-missing:** `Install-Module Az -Scope CurrentUser` and `Install-Module Microsoft.Graph -Scope CurrentUser`. Re-open PowerShell and re-verify the environment switches resolve.

Implementation Guide — Azure Security Baseline & Governance (Government / GCC High)

This guide gives the exact, ordered steps to deploy the governance baseline on an **Azure Government / GCC High** tenant using the sovereign portal `https://portal.azure.us`. Gov-specific caveats appear inline at the step where they matter.

Before you start: complete every requirement in `02-requirements.md`. Sign in at `https://portal.azure.us` — if the URL bar shows `portal.azure.com`, stop; you are in Commercial Azure and these steps do not apply.

Object names (created once, reused verbatim):

Object	Name
Governance root management group	`Governance Root MG`
Platform management group	`Platform MG`
Landing zones management group	`Landing Zones MG`
Custom RBAC role	`Governance Operator – Landing Zones – Pilot`
Policy initiative assignment	`Security Baseline Initiative – Governance Root – Pilot`
Log Analytics workspace	`Governance Logs Workspace – Platform – Pilot`
Pilot subscription tag	`governance-stage = pilot`

Follow the stages in order. Do not skip the pass/fail gate at the end of each stage.

Stage A — Assess (read-only baseline)

A1. Open PowerShell and connect to Azure Government:

```
Connect-AzAccount -Environment AzureUSGovernment
Get-AzEnvironment -Name AzureUSGovernment   # confirm endpoints resolve to *.usgovcloudapi.net
Get-AzSubscription                          # note the pilot subscription id
```

> ***Gov caveat:*** *The* `-Environment AzureUSGovernment` *switch is mandatory. Without it,* `Connect-AzAccount` *targets Commercial endpoints and will not see your Gov subscriptions. Source: [Connect to Azure Government with PowerShell](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).*

A2. Run the discovery script (read-only) to capture the current state:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Discovery.ps1 -SubscriptionId your-subscription-
```

Review the output: current management groups, standing role assignments, policy assignments, Defender for Cloud plan status, and Secure Score. This is your rollback reference (requirement G6).

Gate A (pass/fail): Discovery completes without error, lists your Gov subscription(s), and reports no blocking prerequisite gaps. **Fail** = fix prerequisites in `02-requirements.md` before continuing.

Stage B — Configure (build objects, audit mode)

B1. Enable and build the management-group hierarchy

1. In `portal.azure.us`, search **Management groups**. If prompted, click **Start using management groups**.
2. On the `Tenant Root Group`, click **+ Create** → Name/ID: `Governance Root MG` → **Submit**.
3. Inside `Governance Root MG`, **+ Create** → `Platform MG`. Repeat for `Landing Zones MG`.
4. Move your pilot subscription under `Landing Zones MG` (select the subscription → **Details** → **Move**).

> ***Gov caveat:*** *Management groups behave as in Commercial but are managed only through* `portal.azure.us`*. Source: [Compare Azure Government — Management and governance](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#management-and-governance).*

B2. Create the Log Analytics workspace

1. Search **Log Analytics workspaces** → **+ Create**.
2. Resource group: create or select one in a **US Gov region**. Region: `USGov Virginia` (or your target Gov region). Name: `Governance Logs Workspace – Platform – Pilot` → **Review + Create** → **Create**.

> ***Gov caveat:*** *The workspace lives on* `*.opinsights.azure.us` / `oms.microsoft.us` *endpoints and* ***cannot*** *be migrated to/from Commercial. Choose the correct Gov region now. Source: [Compare Azure Government — Azure Monitor](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-monitor).*

B3. Create the least-privilege custom RBAC role

1. Go to `Landing Zones MG` → **Access control (IAM)** → **+ Add** → **Add custom role**.

2. Name: `Governance Operator – Landing Zones – Pilot`. Baseline permissions: read all resources, manage policy assignments and diagnostic settings, but **not** role assignments or resource deletion. Assignable scope: `Landing Zones MG`.

3. **Review + create**.

4. Assign it to your governance operators (IAM → **+ Add role assignment** → select the custom role → assign to the operating group).

> ***Gov caveat:*** *In Azure Government,* ***Azure Lighthouse PIM (eligible/JIT) authorization is not enabled*** *— this assignment is standing, not "eligible." If your Commercial design used PIM-eligible activation, document a compensating control (e.g. tight scope + Conditional Access). Source: [Compare Azure Government — Azure Lighthouse](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-lighthouse).*

B4. Assign the Azure Policy security-baseline initiative (AUDIT effect first)

1. Search **Policy** → **Assignments** → **Assign initiative**.

2. Scope: `Governance Root MG`. Initiative: choose a secure-configuration initiative (e.g. the built-in **Microsoft cloud security benchmark**, or a custom initiative bundling: deny/audit public blob access, require storage encryption, **allowed locations = US Gov regions only**, audit missing diagnostic settings).

3. Assignment name: `Security Baseline Initiative – Governance Root – Pilot`.

4. **Parameters:** set **Allowed locations** to `usgovvirginia`, `usgovtexas`, `usgovarizona` (and DoD regions if in scope) — **never** Commercial regions like `eastus`.

5. **Set the effect to** `Audit` **/** `AuditIfNotExists` for this stage (not `Deny`). **Review + create**.

> ***Gov caveat:*** *Azure Policy is available in Azure Government and works the same, but the* ***Allowed Locations*** *values must be Gov region names. Using Commercial region names would silently block all deployments. Source: [Connect to Azure Government with PowerShell — regions](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).*

B5. Enable Microsoft Defender for Cloud (Gov-available plans only)

1. Search **Microsoft Defender for Cloud** → **Environment settings** → select your pilot subscription → **Defender plans**.

2. Turn **On** only the plans available in Azure Government: **Servers, Storage, Key Vault, Resource Manager, Containers, DNS, Azure SQL, SQL servers on machines, open-source relational databases**.

3. **Do NOT** attempt to enable **App Service, Cosmos DB, or Foundry/AI** plans — they are **Not Available** in Azure Government and will not appear or will not save. Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

4. Under **Settings & monitoring**, point continuous export / workspace to `Governance Logs Workspace – Platform – Pilot`.

> ***Gov caveat: Recommendation exemption rules****,* ***Adaptive network hardening****,* ***Integrated VA for machines (legacy)****, and* ***AWS/GCP connectors*** *are Not Available in Gov. Do not build runbooks that depend on them. For VM vulnerability findings, rely on Defender for Servers' Microsoft Defender*

Vulnerability Management integration (verify plan coverage in your tenant).

Gate B (pass/fail): All objects exist with the **exact** names above; the policy initiative is assigned in `Audit`/`AuditIfNotExists`; only Gov-available Defender plans are on. Run:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Validation.ps1 -SubscriptionId your-subscription
```

Fail = a named object is missing, an unavailable plan was attempted, or a Commercial region slipped into Allowed Locations. Correct before piloting.

Stage C — Pilot (one subscription, guardrails live)

C1. Tag the pilot subscription: **Subscriptions** → **(pilot)** → **Tags** → add `governance-stage = pilot`. Or use the targeting script:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId your-subs
```

Review the `-WhatIf` output, then re-run with `-Apply` to commit.

C2. For the pilot scope only, change the highest-impact policies from `Audit` to `Deny` (e.g. deny public blob storage, deny non-Gov locations). Edit the assignment `Security Baseline Initiative – Governance Root – Pilot` parameters, or create a pilot-scoped override at the pilot subscription.

Gate C (pass/fail): Validation passes on the pilot scope and no legitimate deployment is unexpectedly blocked. **Fail** = a `Deny` blocks a required workload → adjust the policy parameter or add a scoped exemption (note: use **policy exemptions**, not Defender recommendation exemptions, which are unavailable in Gov).

Stage D — Validate (evidence)

D1. Confirm compliance and Secure Score movement:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Validation.ps1 -SubscriptionId your-subscription
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Report.ps1 -SubscriptionId your-subscription-id
```

D2. In `portal.azure.us` → **Defender for Cloud** → **Regulatory compliance**, confirm the compliance dashboard renders (available in Gov; standards offered may differ from Commercial — Source: [Cloud feature availability — footnote 4](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud)).

D3. Confirm logs are flowing to `Governance Logs Workspace – Platform – Pilot` (workspace → **Logs** → query `AzureActivity | take 10`).

Gate D (pass/fail): Validation + Report show target compliance, Secure Score is tracked, and logs are arriving. Record sign-off. **Fail** = remediate the flagged items (see `05-testing.md`) and re-run.

Stage E — Expand (remaining subscriptions)

E1. For each additional subscription, move it under `Landing Zones MG` and tag it, or run:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId next-subs
```

E2. Promote the validated policy effects (`Deny`) from pilot to the expanded scope by adjusting the assignment scope/parameters. If broad remediation is needed, run the remediation helper (defaults to

`-WhatIf`):

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Remediation.ps1 -SubscriptionId next-subscriptio
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Remediation.ps1 -SubscriptionId next-subscriptio
```

Gate E (pass/fail): Each expanded subscription passes `AZSECG-Validation.ps1`; rollback is rehearsed (requirement G6). **Fail** = roll the subscription back to `Audit` effect, fix, and re-expand.

Rollback (any stage)

- **Policy:** set the assignment effect back to `Audit`/`Disabled` or delete the assignment `Security Baseline Initiative – Governance Root – Pilot`.
- **RBAC:** remove the assignment of `Governance Operator – Landing Zones – Pilot`; the custom role definition can remain.
- **Defender plans:** set the changed plans back to **Off** on the subscription.
- **Management groups:** move subscriptions back to `Tenant Root Group` and delete the empty MGs.

All rollback actions are performed in `portal.azure.us` or via Az PowerShell connected with `-Environment AzureUSGovernment`.

Testing & Validation — Azure Security Baseline & Governance (Government / GCC High)

This section defines the pass/fail tests that prove the governance baseline is correctly deployed on your **Azure Government / GCC High** tenant. Every check is performed against **US Gov endpoints** (`portal.azure.us`, `management.usgovcloudapi.net`, `graph.microsoft.us`). The `AZSECG-Validation.ps1` and `AZSECG-Report.ps1` scripts automate most of these; the portal checks are the manual confirmation.

> *Connect first:* `Connect-AzAccount -Environment AzureUSGovernment` *(Az) and, where directory checks are needed,* `Connect-MgGraph -Environment USGov`*. If either connects to a Commercial endpoint, every test below is invalid.*

Test matrix

#	Test	How to run	Pass criteria	
T1	Correct cloud	`(Get-AzContext).Environment.Name`	Returns `AzureUSGovernment`	
T2	Management-group hierarchy exists	`Get-AzManagementGroup`	`Governance Root MG`, `Platform MG`, `Landing Zones MG` all present	
T3	Custom RBAC role exists & scoped	`Get-AzRoleDefinition "Governance Operator – Landing Zones – Pilot"`	Role exists; assignable scope = `Landing Zones MG`; no `*/delete` or `Microsoft.Authorization/roleAssignments/write`	

#	Test	How to run	Pass criteria	
T4	Policy initiative assigned	`Get-AzPolicyAssignment -Name "Security Baseline Initiative – Governance Root – Pilot"`	Assignment present at `Governance Root MG`	
T5	Allowed Locations = Gov regions only	Inspect initiative parameters	Only `usgovvirginia`, `usgovtexas`, `usgovarizona` (+DoD if scoped); **no** Commercial regions	
T6	Defender plans = Gov-available only	`Get-AzSecurityPricing`	Servers/Storage/KeyVault/ARM/Containers/DNS/SQL/OSS-DB = `Standard`; App Service/CosmosDB/AI **not** attempted	
T7	Log workspace receiving data	Workspace → Logs → `AzureActivity	take 10`	Rows returned within the last 24h
T8	Secure Score tracked	Defender for Cloud → Secure Score	Score renders; baseline recorded	
T9	Compliance dashboard renders	Defender for Cloud → Regulatory compliance	Dashboard loads (standards may differ from Commercial)	
T10	Pilot Deny works	Attempt a public blob or non-Gov-region deploy on pilot	Deployment is **denied** by policy	

Run the automated pass:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Validation.ps1 -SubscriptionId your-subscription
```

A green result requires every applicable row above to pass.

Detailed procedures

T1 — Confirm you are in Azure Government (do this first)

```
(Get-AzContext).Environment.Name    # must be AzureUSGovernment
(Get-AzContext).Environment.ResourceManagerUrl   # must be https://management.usgovcloudapi.net/
```

Fail (returns `AzureCloud` / `management.azure.com`): disconnect (`Disconnect-AzAccount`) and reconnect with `-Environment AzureUSGovernment`. Do not proceed on a wrong-cloud context.

T5 — Allowed Locations must be Gov regions

In `portal.azure.us` → **Policy** → **Assignments** → `Security Baseline Initiative – Governance Root – Pilot` → **Parameters**, confirm the allowed-locations list. A single Commercial region name here will block **all** deployments in a Gov subscription (the region does not exist in the Gov cloud). **Fail** = remove any non-Gov region and re-save.

T6 — Only Gov-available Defender plans enabled

```
Get-AzSecurityPricing | Select-Object Name, PricingTier
```

Confirm the enabled (`Standard`) plans are within the Gov-available set. If you find `AppServices`, `CosmosDbs`, or an AI/Foundry plan attempted, that is a configuration error — those are Not Available in Azure Government. Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud). **Fail** = disable the unavailable plan attempt.

T10 — Confirm the pilot Deny actually blocks

On the **pilot** subscription (`governance-stage = pilot`), attempt to create a storage account with public blob access enabled, or deploy a resource to a Commercial region. Expect a `RequestDisallowedByPolicy` error citing `Security Baseline Initiative – Governance Root – Pilot`. **Fail** (deployment succeeds) = the effect is still `Audit`; switch the relevant policy to `Deny` for the pilot scope and retry.

Regression / re-test cadence

- Re-run `AZSECG-Validation.ps1` after every expansion step (Stage E) and after any policy edit.
- Regenerate the report for audit evidence:

```
powershell -ExecutionPolicy Bypass -File .\scripts\AZSECG-Report.ps1 -SubscriptionId your-subscription-i
```

- Keep each dated report as FedRAMP High audit evidence; store it in the Gov-region Log Analytics workspace or an approved Gov storage account (`blob.core.usgovcloudapi.net`), never a Commercial store.

Exit criteria for "baseline validated": T1–T9 pass on every in-scope subscription, T10 passes on the pilot, the report is generated, and rollback has been rehearsed at least once.

Troubleshooting — Azure Security Baseline & Governance (Government / GCC High)

Gov-specific problems and their fixes. Nearly every issue on a GCC High tenant traces back to one root cause: **something is pointed at the Commercial cloud instead of Azure Government.** Check that first, always.

> *First response to any weird failure: confirm the cloud.* `(Get-AzContext).Environment.Name` *must return* `AzureUSGovernment`*. In the browser, the URL must be* `portal.azure.us`*, not* `portal.azure.com`*.*

1. "I signed in but see no subscriptions / resources"

• **Symptom:** `Get-AzSubscription` is empty, or the portal shows an unfamiliar/empty directory.

• **Cause:** Connected to Commercial. `Connect-AzAccount` without the environment switch defaults to `AzureCloud`, and `portal.azure.com` is the Commercial portal.

• **Fix:** `Disconnect-AzAccount`, then `Connect-AzAccount -Environment AzureUSGovernment`. In the browser, go to `https://portal.azure.us`. Source: [Connect to Azure Government with PowerShell](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).

2. Sign-in redirect / "wrong version number" / TLS or AADSTS redirect errors

• **Symptom:** `Connect-MgGraph` or a portal sign-in throws a redirect/authority error; tokens are rejected.

• **Cause:** Authenticating against the Commercial authority `login.microsoftonline.com` for a Gov tenant homed in `login.microsoftonline.us`, or a proxy that only allows Commercial endpoints.

• **Fix:**

• Graph: `Connect-MgGraph -Environment USGov` (DoD: `-Environment USGovDoD`). Source: [Microsoft Graph national cloud deployments](https://learn.microsoft.com/en-us/graph/deployments).

• Confirm firewall/proxy allows `login.microsoftonline.us`, `graph.microsoft.us`, `management.usgovcloudapi.net`. Source: [endpoint mapping](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#guidance-for-developers).

3. A Defender for Cloud plan won't turn on / doesn't appear

• **Symptom:** Defender for **App Service**, **Cosmos DB**, or a **Foundry/AI** plan is missing from **Environment settings** → **Defender plans**, or refuses to save.

• **Cause:** These plans are **Not Available in Azure Government** — this is expected, not a bug.

• **Fix:** Do not enable them. Enable only the Gov-available plans (Servers, Storage, Key Vault, Resource Manager, Containers, DNS, SQL, OSS DBs). Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

4. "Recommendation exemption" option is missing in Defender for Cloud

• **Symptom:** You cannot exempt an individual Defender recommendation.

• **Cause: Recommendation exemption rules** are **Not Available** in Azure Government.

• **Fix:** Use an **Azure Policy exemption** at the appropriate scope instead, or narrow the policy scope. Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

5. Every deployment is suddenly blocked after assigning the policy initiative

• **Symptom:** `RequestDisallowedByPolicy` on all deployments, citing the Allowed Locations policy.

• **Cause:** A **Commercial region name** (e.g. `eastus`) is in the **Allowed Locations** parameter. That region does not exist in the Gov cloud, so nothing can deploy.

• **Fix:** Edit `Security Baseline Initiative – Governance Root – Pilot` → Parameters → set Allowed Locations to Gov regions only: `usgovvirginia`, `usgovtexas`, `usgovarizona` (and DoD if scoped). Source: [Connect with PowerShell — regions](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).

6. Legitimate work is blocked by a pilot `Deny` policy

• **Symptom:** A required workload fails with a policy `Deny` during pilot.

• **Cause:** The `Deny` effect is too broad for a genuine exception.

• **Fix:** Add a scoped **Azure Policy exemption** for the specific resource/RG, or adjust the policy parameter. Do **not** reach for Defender recommendation exemptions (unavailable in Gov). Re-run `AZSECG-Validation.ps1` after the change.

7. Management groups option is greyed out / root not visible

• **Symptom:** Cannot create `Governance Root MG`; management groups won't load.

• **Cause:** Management groups not yet initialized, or missing root-scope access.

• **Fix:** A Global Administrator elevates access once (Entra ID → Properties → *Access management for Azure resources* → Yes) to get `User Access Administrator` at root, clicks **Start using management groups** in `portal.azure.us`, creates the hierarchy, then removes the elevation. Behaves as Commercial but done in the Gov portal. Source: [Compare Azure Government — Management and governance](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#management-and-governance).

8. "Just-in-time / eligible" role activation isn't available

• **Symptom:** You expected to grant PIM-eligible (JIT) access via Azure Lighthouse and the option is absent.

• **Cause:** In Azure Government, **Azure Lighthouse PIM (eligible/JIT) authorization is not enabled**, and cross-cloud Lighthouse delegation is unsupported.

• **Fix:** Use standing, tightly scoped RBAC (the custom role `Governance Operator – Landing Zones – Pilot`), add Conditional Access, and document this as a compensating control. Source: [Compare Azure Government — Azure Lighthouse](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-lighthouse).

9. MFA "Trusted IPs" setting is missing

• **Symptom:** You cannot configure Trusted IPs for MFA bypass on trusted networks.

• **Cause: Trusted IPs is not supported** in Azure Government.

• **Fix:** Use **Conditional Access named locations** to control when MFA is required. Source: [Compare Azure Government — Microsoft Entra ID](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#microsoft-entra-id-p1-and-p2).

10. Log Analytics workspace has no data / can't move Commercial data in

• **Symptom:** No rows in the workspace, or an attempt to migrate a Commercial workspace fails.

• **Cause:** Wrong endpoints allowed, wrong region, or an attempt to migrate data between clouds (not possible).

• **Fix:** Confirm the workspace `Governance Logs Workspace – Platform – Pilot` is in a **US Gov region**, diagnostic settings point to it, and firewall allows `*.opinsights.azure.us` / `oms.microsoft.us`. **Data cannot be migrated between Commercial and Gov** — start fresh in Gov. Source: [Compare Azure Government — Azure Monitor](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-monitor).

11. Regulatory-compliance dashboard shows different / fewer standards than Commercial

• **Symptom:** The standards list in **Defender for Cloud** → **Regulatory compliance** differs from a Commercial tenant.

• **Cause:** Expected — "there may be differences in the standards offered per cloud type."

• **Fix:** Use the standards that render in your Gov subscription. Confirm coverage before relying on a specific standard (**verify for Azure Government**). Source: [Cloud feature availability — Microsoft Defender for Cloud, footnote 4](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

12. A built-in policy initiative or preview feature is missing

• **Symptom:** The exact built-in initiative or a preview capability you used in Commercial isn't present.

• **Cause:** Built-in definitions and preview features can lag in Gov (Public Preview items often show Not Available in Gov first).

• **Fix:** Pick an available initiative in `portal.azure.us`, or build a custom initiative from available definitions. Re-check the [feature availability page](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability) at deployment time. Flag anything unconfirmed as **verify for Azure Government**.

13. A script says it refuses to run because the cloud is wrong

• **Symptom:** `AZSECG-*.ps1` exits with an environment-guard error.

• **Cause:** By design — the scripts fail fast if `(Get-AzContext).Environment.Name` is not `AzureUSGovernment`, to prevent acting on the wrong cloud.

• **Fix:** `Connect-AzAccount -Environment AzureUSGovernment` (and `Connect-MgGraph -Environment USGov` where the script uses Graph), then re-run.

Escalation checklist

Before opening a support case, capture:

1. `(Get-AzContext).Environment.Name` and `.ResourceManagerUrl` (prove you're in Gov).

2. `Get-AzEnvironment -Name AzureUSGovernment` output (endpoints).

3. The exact error text and the object name involved (use the verbatim names from `03-implementation.md`).

4. A fresh `AZSECG-Discovery.ps1` and `AZSECG-Validation.ps1` output.

5. Whether the feature is listed **Not Available** in Gov on the [feature availability page](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability) — if so, it's a parity gap, not a fault.

Best Practices — Azure Security Baseline & Governance (Government / GCC High)

Operating guidance for running the governance baseline on an **Azure Government / GCC High** tenant over time. These practices assume the baseline from `03-implementation.md` is deployed and validated.

1. Always confirm the cloud before you act

The single most common Gov mistake is operating against the Commercial cloud by habit.

• Bookmark `https://portal.azure.us` (Azure) and `https://portal.office365.us` (M365/Entra admin). Delete or clearly label any `portal.azure.com` bookmark.

• In scripts, **fail fast** if the context is not Gov: check `(Get-AzContext).Environment.Name -eq 'AzureUSGovernment'` before any write. All five solution scripts do this.

• Standardize on `Connect-AzAccount -Environment AzureUSGovernment` and `Connect-MgGraph -Environment USGov` in every runbook. Source: [Connect to Azure Government with PowerShell](https://learn.microsoft.com/en-us/azure/azure-government/documentation-government-get-started-connect-with-ps).

2. Least privilege — standing scope, documented compensating controls

• Assign RBAC at the **highest management-group scope** you truly need, and let inheritance do the rest — don't sprinkle per-subscription `Owner`.

• Prefer the custom role `Governance Operator – Landing Zones – Pilot` over built-in `Contributor` for day-to-day governance work.

• **Gov reality:** Azure Lighthouse **PIM eligible/JIT authorization is not enabled** in Azure Government, so "just-in-time" role activation via Lighthouse is unavailable. Compensate with tight scope, Conditional Access, and periodic access reviews — and **document** that PIM-eligible access is not available in this cloud. Source: [Compare Azure Government — Azure Lighthouse](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-lighthouse).

3. Policy-first guardrails, audit before deny

• Roll out every new policy as `Audit`/`AuditIfNotExists` first, observe compliance, then promote to `Deny` on the pilot scope, then expand.

• Keep **Allowed Locations** pinned to Gov regions (`usgovvirginia`, `usgovtexas`, `usgovarizona`, DoD as needed). Re-check this parameter after any template import — a stray Commercial region name blocks every deployment in the Gov cloud.

• Use **Azure Policy exemptions** for legitimate exceptions. Do **not** design around **Defender recommendation exemption rules** — they are **Not Available** in Azure Government. Source: [Cloud feature availability — Microsoft Defender for Cloud](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability#microsoft-defender-for-cloud).

4. Enable only the Defender plans that exist in Gov

• Enable and keep on: **Servers, Storage, Key Vault, Resource Manager, Containers, DNS, Azure SQL, SQL on machines, open-source relational DBs**.

• Never build automation that assumes **App Service, Cosmos DB, Foundry/AI, adaptive network hardening, integrated legacy VA, or AWS/GCP connectors** — all Not Available in Gov.

• For VM vulnerability findings, use Defender for Servers with the **Microsoft Defender Vulnerability Management** integration rather than the legacy built-in scanner (verify plan coverage in your tenant, and flag "verify for Azure Government" if a specific sub-feature is not confirmed for your region).

5. Centralize audit logging in-cloud, keep it in-cloud

• Send activity and diagnostic logs to `Governance Logs Workspace – Platform – Pilot` in a US Gov region.

• **Data cannot be migrated** between Commercial and Gov workspaces — pick the right region once. Source: [Compare Azure Government — Azure Monitor](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#azure-monitor).

• Store exported audit evidence only on Gov storage (`blob.core.usgovcloudapi.net`), never a Commercial account, to preserve data-residency and export-control posture.

6. Identity hardening the Gov way

• Enforce MFA with **Conditional Access named locations**, not **Trusted IPs** — Trusted IPs is **not supported** in Azure Government. Source: [Compare Azure Government — Microsoft Entra ID](https://learn.microsoft.com/en-us/azure/azure-government/compare-azure-government-global-azure#microsoft-entra-id-p1-and-p2).

• Be aware **B2B collaboration** has known limitations in Gov and **Azure AD B2C is not available** — do not design external-identity flows that depend on them without verifying availability in your tenant.

7. Change control, rollback, and evidence

• Treat every `Deny` promotion and scope expansion as a change record with a scheduled window (requirement G5) and a rehearsed rollback (requirement G6).

• Capture a fresh **discovery** snapshot before each change and a **validation + report** snapshot after — these are your before/after audit evidence.

• Rehearse rollback (policy → `Audit`, remove RBAC assignment, Defender plan → Off, MG move-back) at least once before expanding beyond the pilot.

8. Keep tooling current and Gov-aware

• Keep the **Az** and **Microsoft.Graph** modules current so the `AzureUSGovernment` / `USGov` environment switches resolve.

• Re-verify endpoints periodically with `Get-AzEnvironment -Name AzureUSGovernment` — Microsoft occasionally adds Gov endpoints as parity improves.

• Track Microsoft's [Cloud feature availability](https://learn.microsoft.com/en-us/azure/security/fundamentals/feature-availability) page; Gov parity gaps close over time, and a feature marked Not Available today may become GA — re-confirm before relying on it.

9. Naming discipline

Reuse the exact object names from `03-implementation.md` in every script, ticket, and audit artifact. Consistent `<Purpose> – <Scope> – <Stage>` naming makes validation deterministic and audit review fast.

Deliverables Summary — Azure Security Baseline & Governance (Government / GCC High)

Everything included in this solution package, and what each piece is for. All content is authored for **Azure Government / GCC High** — sovereign `*.us` portals and US Gov endpoints throughout.

Documentation

Document	Purpose
`executive-summary.md`	One-page business framing: why Gov differs from Commercial and what the solution delivers.
`01-solution-overview.md`	The solution, the deployment model, and an explicit **Commercial vs Azure Government — what's different** section.
`02-requirements.md`	Solution-specific prerequisites (Gov subscription, Gov licensing, roles, MG access, Defender scope, Log Analytics, endpoints, modules) — each with Description / Why / Verify / Implement-if-missing.

Document	Purpose
`03-implementation.md`	Exact ordered steps using `portal.azure.us`, Assess→Configure→Pilot→Validate→Expand, with Gov caveats inline and named objects.
`05-testing.md`	Pass/fail test matrix and procedures, validated against US Gov endpoints.
`06-troubleshooting.md`	Gov-specific gotchas (wrong cloud, endpoint/redirect errors, unavailable plans, region traps) and fixes.
`07-best-practices.md`	Ongoing operating guidance for the baseline on a Gov tenant.
`gcc-high-parity-notes.md`	Concise Commercial-vs-Gov reference; every row cited to a Microsoft doc or flagged **verify for Azure Government**.
`global-requirements-azure-solutions.md`	Shared platform prerequisites common to all Azure solutions.

Scripts (`scripts/`)

All scripts connect to **US Gov endpoints** (`Connect-AzAccount -Environment AzureUSGovernment` / `Connect-MgGraph -Environment USGov`) and fail fast if the context is not Azure Government.

Script	Mode	Purpose
`AZSECG-Discovery.ps1`	Read-only	Inventory current MGs, RBAC, policy, Defender plans, Secure Score — the pre-change baseline.
`AZSECG-Validation.ps1`	Read-only	Run the pass/fail test matrix against the deployed baseline.
`AZSECG-Report.ps1`	Read-only	Produce an HTML evidence report (compliance, Defender plans, Secure Score, log flow).
`AZSECG-Remediation.ps1`	`-WhatIf` **by default**	Trigger policy remediation / bring resources into compliance; requires `-Apply` to commit.
`AZSECG-Set-ScopeTargeting.ps1`	`-WhatIf` **by default**	Tag/move subscriptions into the governance stage (pilot/expand); requires `-Apply` to commit.

Named objects the solution creates

Object	Name
Governance root MG	`Governance Root MG`
Platform MG	`Platform MG`
Landing zones MG	`Landing Zones MG`
Custom RBAC role	`Governance Operator – Landing Zones – Pilot`
Policy initiative assignment	`Security Baseline Initiative – Governance Root – Pilot`
Log Analytics workspace	`Governance Logs Workspace – Platform – Pilot`
Pilot subscription tag	`governance-stage = pilot`

How to use the package

1. Read `executive-summary.md` and `01-solution-overview.md` (especially the Commercial-vs-Gov section).
2. Work through `02-requirements.md`; verify each item in `portal.azure.us`.
3. Follow `03-implementation.md` stage by stage; run the scripts where indicated.
4. Validate with `05-testing.md`; keep `AZSECG-Report.ps1` output as audit evidence.
5. Consult `06-troubleshooting.md` and `gcc-high-parity-notes.md` whenever behavior differs from Commercial expectations.

Definition of done

Named governance hierarchy in place; least-privilege RBAC assigned; policy initiative enforced and proven on the pilot; Gov-available Defender plans on with Secure Score tracked; audit logs flowing to the Gov-region workspace; validation + report evidence captured; rollback rehearsed.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

AZSECG-Discovery.ps1

Purpose: Captures the current governance posture on an Azure Government tenant: management-group hierarchy, standing role assignments, policy assignments, Microsoft Defender for Cloud plan status, and Secure Score. This is the pre-change baseline and rollback reference. It writes nothing and changes nothing. Provide your subscription id as 'your-subscription-id'. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\AZSECG-Discovery.ps1 -SubscriptionId your-subscription-id

How to run: powershell -ExecutionPolicy Bypass -File .\AZSECG-Discovery.ps1 -SubscriptionId your-subscription-id

AZSECG-Remediation.ps1

Purpose: Triggers Azure Policy remediation tasks for deployIfNotExists/modify policies within the security-baseline initiative on an Azure Government subscription, so non-compliant resources are brought into line. Defaults to preview mode (-WhatIf); nothing changes until you pass -Apply. Provide 'your-subscription-id'. Never enables Gov-unavailable Defender plans. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\AZSECG-Remediation.ps1 -SubscriptionId your-subscription-id Commit changes: powershell -ExecutionPolicy Bypass -File .\AZSECG-Remediation.ps1 -SubscriptionId your-subscription-id -Apply

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\AZSECG-Remediation.ps1 -SubscriptionId your-subscription-id Commit changes: powershell -ExecutionPolicy Bypass -File .\AZSECG-Remediation.ps1 -SubscriptionId your-subscription-id -Apply

AZSECG-Report.ps1

Purpose: Produces a dated HTML report summarizing the governance baseline on an Azure Government subscription: cloud/endpoint confirmation, management groups, policy assignments and compliance, Microsoft Defender for Cloud plans, and Secure Score. For audit evidence (FedRAMP High). Read-only. Provide 'your-subscription-id' and an output path. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\AZSECG-Report.ps1 -SubscriptionId your-subscription-id -OutputPath .\AZSECG-report.html

How to run: powershell -ExecutionPolicy Bypass -File .\AZSECG-Report.ps1 -SubscriptionId your-subscription-id -OutputPath .\AZSECG-report.html

AZSECG-Set-ScopeTargeting.ps1

Purpose: Assigns the governance-stage tag (pilot/expand) to a subscription and, optionally, moves it under the Landing Zones management group so the baseline policy and RBAC apply by inheritance. Defaults to preview mode (-WhatIf); nothing changes until you pass -Apply. Provide 'your-subscription-id' and the target stage. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId your-subscription-id -Stage pilot Commit: powershell -ExecutionPolicy Bypass -File .\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId your-subscription-id -Stage pilot -Apply

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId your-subscription-id -Stage pilot Commit: powershell -ExecutionPolicy Bypass -File .\AZSECG-Set-ScopeTargeting.ps1 -SubscriptionId your-subscription-id -Stage pilot -Apply

AZSECG-Validation.ps1

Purpose: Runs the AZSECG test matrix against a deployed baseline on an Azure Government subscription: correct cloud, management-group hierarchy, least-privilege custom role, policy initiative assignment, Gov-region Allowed Locations, Gov-available Defender plans only, and Secure Score presence. Read-only — it verifies, it does not change anything. Use 'your-subscription-id'. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\AZSECG-Validation.ps1 -SubscriptionId your-subscription-id

How to run: powershell -ExecutionPolicy Bypass -File .\AZSECG-Validation.ps1 -SubscriptionId your-subscription-id